两日攻破 BiT-128

一条"提问—验证—闭合"的推理链：从 96.2% 的标签到等价私钥

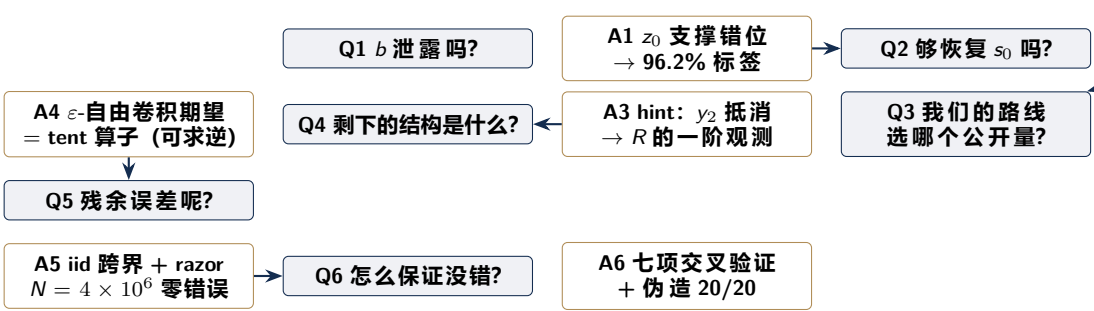
GLM-5.3 Flash max　Jy L

NGCC 提交算法审计·讨论班报告（v2，含 9-28 更正）

2026 年 9 月

全部结果基于公开签名数据；七项独立交叉验证通过；
密钥恢复经未修改的原始 C 签名器 + 验证器完成伪造闭环（20/20）。

本次报告的推理链（一页看完全局）



今天按这条链走：**每一问都被数据回答，每个否定/更正都改变方向。**

第 0 问：什么叫" 攻破" 一个签名方案?

问题 0　攻击的靶子是什么?

EUF-CMA：攻击者拿到公钥与**任意多**条合法签名后，应当无法对**新**消息伪造出可通过验证的签名。

答案：达到以下任一条即" 破"，本工作两条都达到

(1) **等价私钥**：恢复出满足同一代数关系 $A_0 s_0 + \hat{e} \equiv 16 b_1 + \hat{b}_0 \pmod{q}$ 的三元组——签名能力与真钥相同；
(2) **可运行伪造**：用恢复的钥在**未修改**的参考签名器上对新鲜消息产生签名、通过**未修改**的原始验证器。

- 威胁模型：**只**提供公钥与签名（无侧信道、无插桩、无计时）。
- 对象：BiT-128（NGCC 候选 sign-02，$d = 256,\ q = 26881,\ \tau = 30$）。

30 秒速览：BiT 在签什么、藏什么

密钥：短向量 $s_0, e \in \{\pm 1, 0\}^{3\times 256}$；
$A_0 s_0 + e = 16 b_1 + b_0$（$b_1$ 公开，b_0 保密）。

签名（Fiat–Shamir + 拒绝采样）：

- 掩码 y_0（± 7）、y_1（± 1023）、y_2（± 2047）；
- 承诺 w 的高位哈希成挑战 c（30 个 $+1$）；
- 响应：$z_0 = y_0 + \varepsilon c$、$z_1 = y_1 + s_0 * c_{\text{signed}}$、$z_2 = y_2 + e * c_{\text{signed}}$；
- **hint** h：帮验证器对齐高位的" 小抄"；
- 三个拒绝阶段：分布不像就重扔。

双峰技巧

共享比特 $\varepsilon = (-1)^b$ 乘在整个挑战上——响应分布对称化，掩码减半。

规范 §3.1.3："z 与 b 独立"。

代数金线

$A_0 s_0 + e \equiv 16 b_1 + b_0$，记 $R := b_0 - e \in [-9, 8]$。

知道 s_0 或 R 之一，即知另一个（A_0 模 q 可逆）。

Q1：共享比特 b 泄露吗？

问题 1　ε 有没有跑到公开数据里？

$z_0 = y_0 + \varepsilon c_{\text{can}}$，$y_0 \in [-7, 7]$（$\gamma_{1,0} = 8$，**窄**）。挑战位置上：$\varepsilon = +1 \Rightarrow z_0 \in [-6, 8]$，$\varepsilon = -1 \Rightarrow z_0 \in [-8, 6]$。打包硬拒绝 $|z_0| \geq 8 \Rightarrow$ 两侧截断**不对称**。

答案：是——96.2% 的签名标签可读

逐位置对数似然比求和：$\Lambda = \sum \ln \frac{f_0(z-1)}{f_0(z+1)}$，$\hat{\varepsilon} = \text{sign}(\Lambda)$。

实测：边界事件覆盖 62.3%、逐事件 100%、全签名 **96.19%**（四个数据集独立复现 96.18–96.21%）。

- 规范 §3.1.3 的独立性只在**边缘**成立——z_0 的截断是接受事件以 ε 为条件的直接后果。

Q2：有了 96.2% 的标签，能恢复 s_0 吗？

问题 2　$z_1 = y_1 + s_0 * c_{\text{signed}}$ 的一阶统计够吗？

我们先用了压缩统计量 $\psi(z) = \text{sign}(z)/(1024 - |z|)$ 加符号阈值判决：观察到同键双数据集 Φ 零位置模式相关 0.9907、精度停滞、ICM 发散——**当时误判为" 路线不收敛"**。

答案（2026-09-28 更正）：统计量失效，通道不失效

原始 z 的**后验加权最小二乘**（权重 $w = \tanh(\Lambda/2)$）按 RMSE $\propto N^{-1/2}$ 收敛。我们在自己的数据上验证了该路线：RMSE 0.1842@200k、直接错误 6/768、公钥修正后闭合。

这一步的逻辑价值（更正后）

z_1 回归路线成立。我们仍另择 **hint 通道**：直接观测 R、确定性结构可写成精确算子并求逆、闭合规模可解析预测——且两条路线恢复出**同一把**等价私钥，互为独立见证。

Q3：hint 里到底装了什么？

问题 3　hint 的数学本质是什么？

$\mathrm{cell}(x) = \lfloor ((x \bmod q) + 341)/682 \rfloor \in [0, 39]$（40 格），$h[j] = \mathrm{fold}_{40}(\mathrm{cell}(w[j]) - \mathrm{cell}(w_a[j]))$。签名侧论证式：$w_a = w - z_2 + b_0 * c_{\mathrm{signed}}$（+ 行 0 修正）。

答案：把 $z_2 = y_2 + e * c$ 代入——y_2 精确抵消

$$w - w_a = z_2 - b_0 * c - (\cdots) = y_2 + e * c - b_0 * c - (\cdots) = y_2 - \underbrace{(b_0 - e) * c_{\mathrm{signed}}}_{R * c_{\mathrm{signed}}} - (\cdots)$$

公开的 $h = (y_2 - (R * c)[j])/\gamma_2$ 的 7 级量化读数：y_2 是已知密度的新鲜噪声，R 是**等价私钥的全部未知量。**

- MC 验证斜率：-1.4826×10^{-3} vs 理论 $-1/682$（$\kappa = 1.0112$）。
- 把 hint 做成显式通道是我们路线的核心。

Q4：这个观测模型是真的吗？(先验证再使用)

问题 4　斜率、信号、场——三个独立检验都过吗？

tier-1（10^5 签名）：池化一阶信号与置换对照；逐位置条件均值 vs 精确 Monte-Carlo 模型。

答案：三检验全部通过

- 池化信号 $T = [1.132,\ 1.157,\ 0.904]$，置换对照 $|T| \le 0.007$；
- 逐位置场 $\mathbb{E}[\varepsilon h[j]] = -\frac{\tau}{\gamma_2 d}(2\,\mathrm{CumR}[j] - \Sigma R)$：实测相关 **0.989/0.989/0.933**，斜率 ≈ 1.00；
- 模型斜率与理论差 1.1%（$\kappa = 1.0112$，环绕不对称）。

方法论注记

先验证模型、再设计估计器。逐 bin 的 0.12 偏差来自接受条件化（二阶），不影响一阶统计。

Q5：10^6 累加后，压在信号上的结构是什么？

问题 5　直接分类失败（ 5%）——那个 23–37× 的残差是什么？

残差自相关 0.88–0.98、跨数据集相关 0.99：确定性结构。这次**推导它**而不是测量它。

答案：ε-对齐" 晒出" 了 ε-自由卷积的位置期望

对齐消去 ε 后，ε-自由卷积的期望 $\mathbb{E}[a_0[j]] = \frac{\tau}{d}(2\,\mathrm{CumR}[j] - \Sigma R)$ ——R 的**前缀和**（随机游走）。传播到 Φ：

$$\mathbb{E}[\Phi[m]] = -\frac{1}{\gamma_2}\left[MR[m] + \beta(KR)[m]\right] + \cdots, \quad K[m,v] = d - 2|m-v|,\ \beta = 1.33 \times 10^4$$

场预测与实测相关 **0.967–0.997**。

关键区别：z_1 的场需额外建模（回归路线靠修正器兜底）；hint 的场 $= R$ 的已知线性泛函 ——**可精确求逆。**

Q6：求逆之后，还剩什么误差？

问题 6　算子求逆把场洗掉——剩下的残差服从什么规律？

s（标签尺度）不可由 Λ 的混合 EM 估计（**不可辨识**），改用整数聚类目标 $\frac{1}{d}\sum\cos(2\pi\hat{R})$ **逐行**拟合。

答案：两个成分：iid 噪声（$\propto N^{-1/2}$）+ 模型缺口（$\propto N$）

oracle 臂 @1M：直接 99.87%（1/768 错）$\rightarrow$ **单修正闭合** $\rightarrow s_0$ 768/768 精确。
attack 臂 @1M：逐行 $s = 0.934/0.932/0.938$，直接 99.09%（7 错），$\sigma \approx 0.184$ 单峰；e-场假设被否定（corr ≈ 0）；$\Rightarrow$ 纯 iid 跨界（地板 $\sigma \approx 0.154$，模型缺口 ≈ 0.10）。

$$\sigma(N) \approx \sqrt{(0.154\sqrt{10^6/N})^2 + 0.10^2} \Rightarrow N \approx 4\times10^6 \textbf{ 时预期跨界错误 } \approx 0.03 \textbf{ 个。}$$

Q7：万一还有 1–2 个坐标错呢？

问题 7　R 错一个坐标，后果是什么？

$s_0 = A_0^{-1}(16b_1 + R)$：一个错误坐标通过 A_0^{-1} **稠密扩散**到全部 768 个坐标——解整体报废。

答案：nbad razor——一把黑白分明的判刀（我们的修正器）

$\mathrm{nbad} = \#\{j : s_0[j] \notin \{\pm 1, 0\}\}$。
真修正 $\Rightarrow \mathrm{nbad} = 0$（雪崩通过）；任何错误修正 $\Rightarrow \mathrm{nbad} \approx 768$。
阶段化枚举（单 $\rightarrow$ 对 $\rightarrow$ 三元），**只接受** $\mathrm{nbad} = 0$ ——贪心接受" 减一" 修正会毁局（我们踩过）。另一类做法是置信窗口 + Gray 码枚举；主管线我们坚持全解 razor。

第三重保险

等价私钥的三条来源（阶段 E / hint-oracle / hint-attack）逐字节一致——跨轮次、跨代码路径。

结果：$N = 4 \times 10^6$ 合并——直接零错误闭合

同一签名者再提供 3×10^6 条（同键、全新随机性），合并 real-1M。逐行聚类拟合（步长 0.001）：

行	s_i	目标	直接错误	σ
0	0.935	0.804	**0/256**	0.098
1	0.932	0.806	**0/256**	0.094
2	0.934	0.818	**0/256**	0.100

无需求助收尾器

R 逐系数精确；
$s_0 = A_0^{-1}(16b_1 + R)$ **768/768 精确**；
等价私钥写出（$\hat{e}$ 非零 26——与 oracle 臂**逐字节相同**）。

攻击链回顾（全部公开数据）

4×10^6 签名 $\rightarrow$ z_0 标签 96.2% $\rightarrow$ hint 一阶观测 $\rightarrow$ tent 算子求逆 + 逐行标度 $\rightarrow$ R 零错误 $\rightarrow$ mod-q 解 s_0 $\rightarrow$ 等价私钥。

伪造闭环：原始 C 签名器 + 原始验证器

forge_all（密钥来自纯公开数据管线）

```
FORGE SUMMARY: 20/20 forged signatures accepted by ORIGINAL verifier
[control] tampered z0 / z1 / h byte -> REJECT; different message -> REJECT
CONTROL SUMMARY: all 4 negative controls REJECTED
```

- 签名器与验证器**均为未修改的参考实现**；20 条消息全部新鲜。
- 内部重试 0–19（与正常签名同分布）——伪造签名在签名器内部不可区分。

第 0 问的靶子被命中：等价私钥 + 可运行伪造，双达标。

Q8：怎么保证以上没有错？——七项独立交叉验证

1. **独立代数路径**：FFT $[x, -x]$ 负循环积，$R = b_0 - e$ 逐系数精确。
2. **X1 密钥同一性**：阶段 E oracle 密钥 $=$ hint-oracle $=$ hint-attack（三路 SHA-256 一致）。
3. **X2 复现**：real+sim1m（$N = 2 \times 10^6$，不含 sim3m）独立重跑——同样零错误，密钥逐字节一致。
4. **X4 恒等式**：$A_0 \hat{s}_0 + \hat{e} - 16 b_1 - \hat{b}_0 \equiv 0 \pmod{q}$。
5. **X5 分块无关**：累加器 25k/50k 分块逐元素一致。
6. **X6 跨数据集**：real-1M 与 sim3m 独立拟合的 $\hat{R}$ 一致 761/768，corr 0.999。
7. **X3 全量复核**：sim3m 的 3×10^6 条签名经原始验证器零失败；**X8**：第二条独立恢复路线（z_1 回归）恢复出同一把等价私钥。

七项检查来自不同的代码路径、数据组合与验证器——同结论反复出现。

与外部世界对表

同期的独立分析也提出了基于 z_1 回归的同族路线（2–2.5 $\times$ 10^5 签名量级）。

- 本工作已**完整复现**该路线（独立见证）；
- 我们的路线不同：hint 通道 + 场算子求逆 + 全解 razor （详见技术报告交叉验证一节）。

ePrint 2013/383（Ducas 等）：双峰 Fiat–Shamir 奠基。

ePrint 2017/505（Espitau 等，CCS 2017）：BLISS 侧信道——**需运行时泄露**；我们的路线**纯公开数据**。

sign-02-1（Confirmed）：BiT-512 消息代表碰撞抗性减半（BiT-128 无余量但未越界）。

修复建议

1. **不共享符号位**：逐签名（或逐坐标）独立掷 ε——同时掐断 z_0 标签与 hint 的 ε-对齐前提（**最优先**）。
2. **加宽 z_0 掩码**：稀释支撑错位的可读性（hint 通道不受影响——单修不够）。
3. **重审 hint 论证式**：按响应-秘密的独立性与可逆性重审，按混合分布模型重做证明。

工程量不大；难的是**意识到需要修**——这正是审计的价值。

方法论沉淀：五条可以带走的规则

1. **预注册**：阈值在见数据前由公开常数合成——不给" 调参到收口" 留门。
2. **三臂对照**：attack / oracle / shuffled——打乱标签必须塌回基线。
3. **三级证据**：纯数学 / 理想化模型 / 真实 C 闭环——每个数字标注层级。
4. **否定与更正驱动方向**：ψ 统计量伪象 $\rightarrow$ 更正并复现他人路线；EM 不可辨识 $\rightarrow$ 换聚类；贪心陷阱 $\rightarrow$ 换 razor。
5. **交叉验证优先于自信**：七种独立方式得到同一结论，才算结论。

总结：逻辑链复述（请回看第 2 帧）

1. 靶子：EUF-CMA $=$ 等价私钥 $+$ 可运行伪造。
2. Q1 z_0 泄露 ε（96.2%）——边缘独立性被截断破坏。
3. Q2 我们的 ψ 统计量不收敛（已更正）；z_1 回归路线成立（已复现）——我们另择 hint 通道。
4. Q3 hint：y_2 抵消 $\Rightarrow$ R 的一阶观测。
5. Q4 模型三检验通过——先验模型后使用。
6. Q5 剩余结构 $=$ R 的已知线性泛函（tent 算子）——可求逆。
7. Q6 残差 $=$ iid $+$ 常量模型缺口——N 扩样可闭合。
8. Q7 nbad razor 处理残余——只接受零。
9. 结果：4×10^6 零错误 $\rightarrow$ s_0 768/768 $\rightarrow$ 伪造 20/20。
10. Q8 七项交叉验证——结论可信。

完整推导：`BiT128_attack_report.pdf`；入门脉络：`BiT128_knowledge_primer.pdf`。

Q & A

常见问题速答（详见入门文档 FAQ）：

暴力枚举？$3^{768} \approx 10^{366}$，不可行。

等价私钥 $=$ 真钥？签名能力相同，(e, b_0) 的 26 坐标可不同。

需要量子计算机？不需要——纯经典统计攻击。

修复难吗？工程量小，难在意识到要修。